Evidencia 2 Semana 6

Ariel Esteban Morillo Mosquera
Universidad de las Fuerzas Armadas ESPE
19 de octubre de 2026

1. Referencia y enlace

Magdalena Glas, Christoph Nirschl, Bar Lanyado y Johan van Niekerk. (2026). *Insecure by design? A human-centric security perspective on AI-assisted software development*. Computers & Security, 164, artículo 104842.

https://doi.org/10.1016/j.cose.2026.104842

Texto completo de acceso abierto

2. Problema

Los autores estudian cómo el código generado por IA puede introducir vulnerabilidades y cómo la confianza excesiva dificulta su revisión. (pp. 1-3).

3. Objetivo

Buscan orientar una adopción segura de estos asistentes mediante recomendaciones para desarrolladores, organizaciones y docentes. (p. 1).

4. Metodología

Es un análisis de estudios previos y ejemplos de código. Examina una función de carga de archivos generada por GPT-4o y menciona pruebas, Bandit y CodeQL como herramientas de apoyo. (pp. 2-5).

5. Resultados

Identifica tres problemas: generación de código inseguro, aceptación poco crítica y dificultades de evaluación. Propone combinar revisión humana, herramientas y formación. El aporte es una síntesis de riesgos y recomendaciones; no presenta mediciones experimentales propias. (pp. 2-6).

6. Limitaciones

Considero que las recomendaciones necesitan probarse en un proyecto concreto. Me gustaría conocer su coste para un equipo pequeño y qué fallos pasarían inadvertidos. También comprobaría si funcionan igual con distintas versiones de los modelos. Por eso, no tomaría esta lectura como una comparación que permita elegir el asistente más seguro.

7. Mi reflexión

Me queda más clara la diferencia entre conseguir que una función se ejecute y saber si es segura. Para mi formación en backend, eso significa que debo poder explicar y revisar el código que acepto de una IA. También me interesa investigar cómo comprobar una solución sin depender únicamente de que el mismo modelo diga que está bien.

La pregunta que me queda es: ¿qué combinación de pruebas automatizadas y revisión humana permitiría detectar fallos funcionales y de seguridad en una API generada por IA, sin volver demasiado lento el desarrollo?